

README DEL KIT GQM+PRAGMATIC DREAD

Guía de Inicio Rápido y Documentación Completa

Marco Integrativo para la Medición de Ciberseguridad • Edición 2025-2026

"Todo kit de herramientas tiene un README. Este tiene además la ventaja de que, si lo lees, es porque ya tienes el problema lo suficientemente bien formulado como para resolverlo."

¿QUÉ ES ESTE KIT?

El **Kit GQM+PRAGMATIC DREAD** es un marco metodológico integral para la medición cuantitativa de la ciberseguridad organizacional, diseñado específicamente para el contexto regulatorio español (NIS2/LCGC-2025, ENS, DORA, GDPR) con perspectiva comparativa europea e internacional.

El kit combina tres metodologías de probada eficacia:

- **DREAD** (Damage, Reproducibility, Exploitability, Affected Users, Discoverability): modelo de puntuación de amenazas desarrollado por Microsoft y adaptado para uso organizacional e institucional
- **GQM** (Goal-Question-Metric): metodología de Basili, Caldiera y Rombach (1994) que garantiza la trazabilidad desde objetivos estratégicos hasta datos técnicos
- **PRAGMATIC** (Brotby & Hinson, 2013): método de evaluación de la calidad intrínseca de las métricas de seguridad

Aplicación objetivo: Organizaciones españolas sujetas a NIS2, ENS y/o DORA que desean implementar un programa de métricas de ciberseguridad trazable, auditables y con justificación económica ante el Consejo de Administración.

ESTRUCTURA DEL KIT: 7 DOCUMENTOS

Kit_GQM_PRAGMATIC_DREAD/

- a_marco_GQM_PRAGMATIC.md ← ESTE ES EL PUNTO DE PARTIDA
Marco teórico completo: GQM+PRAGMATIC aplicado a DREAD
Árbol GQM con 23 métricas, fórmulas, umbrales y fuentes
Tabla maestra de trazabilidad (Objetivo Nacional → Métrica técnica)
- b_matriz_PRAGMATIC.md ← PARA EVALUAR LA CALIDAD DE CADA MÉTRICA
Evaluación criterio por criterio (9 criterios × 23 métricas)
Ranking completo de las 23 métricas por puntuación PRAGMATIC
Análisis de patrones y recomendaciones de adopción por fases
- c_narrativa_explicativa.md ← PARA ENTENDER EL "POR QUÉ"
Por qué DREAD necesita GQM (el problema de la subjetividad)
Cómo interpretar los resultados (10 principios)
Contexto normativo español y europeo 2025-2026
- d_mapeo_normativo.md ← PARA CUMPLIMIENTO REGULATORIO Y AUDITORÍA
Tabla completa: cada métrica ↔ NIS2/ENS/DORA/GDPR/ISO27001/CRA
Clasificación obligatorio vs. recomendado
Evidencias de auditoría por métrica
- e_plantilla_excel_IGM_ROI.md ← PARA IMPLEMENTAR LA MEDICIÓN
Especificación completa de las 9 hojas del libro Excel
Fórmulas de cálculo IGM, ROI, VAN, Payback, ROSI
Presets sectoriales, benchmarks, scoring de amenazas
- f_plantilla_powerpoint.md ← PARA REPORTAR AL CONSEJO
18 diapositivas especificadas en detalle
Mensajes ejecutivos por dimensión DREAD
Protocolo de presentación + 10 reglas de oro
- g_README_kit_encuesta.md ← ESTÁS AQUÍ
Guía de inicio rápido
FAQ y tabla de fuentes científicas

INICIO RÁPIDO: 3 PERFILES DE USUARIO

● PERFIL A — CISO / Director de Seguridad (tiempo disponible: 2 horas)

Objetivo: Evaluar el estado actual de la organización y preparar la presentación al Consejo.

Ruta de lectura:

1. Leer c_narrativa_explicativa.md (Sección III: Grupos de métricas por comportamiento) — 20 min
2. Abrir e_plantilla_excel_IGM_ROI.md y seguir el Paso 1 (Preparación) — 30 min
3. Cumplimentar las métricas disponibles en HOJA 2 del Excel — 45 min
4. Preparar la presentación usando f_plantilla_powerpoint.md (diapositivas 3, 4, 10, 12, 17) — 25 min

Resultado esperado: Presentación de 8 diapositivas lista para el Consejo con IGM_Global calculado.

● PERFIL B — Analista de Riesgos / GRC Manager (tiempo disponible: 1 jornada)

Objetivo: Implementar el marco completo de métricas GQM+PRAGMATIC en la organización.

Ruta de trabajo:

1. Leer a_marco_GQM_PRAGMATIC.md completo — 60 min
2. Revisar b_matriz_PRAGMATIC.md para seleccionar las métricas de implementación prioritaria según las tres fases recomendadas — 45 min
3. Verificar el alineamiento regulatorio con d_mapeo_normativo.md — 30 min
4. Implementar el libro Excel siguiendo e_plantilla_excel_IGM_ROI.md — 3 horas
5. Documentar las métricas no disponibles y construir el plan de implantación — 1 hora

Resultado esperado: Libro Excel completo con IGM_Global, scoring de amenazas y modelo ROI preliminar.

PERFIL C — Investigador / Consultor (tiempo disponible: sin restricción)

Objetivo: Comprender la base metodológica completa para adaptación, extensión o investigación.

Ruta de lectura:

1. c_narrativa_explicativa.md completo (base filosófica y epistemológica)
2. a_marco_GQM_PRAGMATIC.md completo (metodología técnica)
3. b_matriz_PRAGMATIC.md completo (evaluación metametría)
4. d_mapeo_normativo.md completo (contexto normativo)
5. Bibliografía científica completa (ver sección FUENTES más abajo)

Nota para investigadores: Los indicadores DREAD propuestos pueden extenderse con vectores adicionales (p.ej., ataques cuánticos, deepfakes, desinformación técnica) siguiendo el mismo árbol GQM. La puntuación PRAGMATIC de las métricas emergentes (< 65 puntos) refleja la madurez metodológica actual, no la importancia estratégica del vector.

PREGUNTAS FRECUENTES (FAQ)

¿El kit es de uso libre?

Sí. El kit se distribuye bajo licencia Creative Commons Attribution 4.0 International (CC BY 4.0). Puede usarse, adaptarse y redistribuirse libremente citando la fuente original.

¿Cuánto tiempo requiere implementar el kit completo?

La implementación básica (métricas de Fase 1, Excel parcial, presentación al Consejo) requiere 3-5 días laborables. La implementación completa con todas las métricas, integración de fuentes y automatización requiere 4-8 semanas dependiendo de la madurez tecnológica de la organización.

¿Qué ocurre si no tengo datos para algunas métricas?

Registrar -1 en la columna E de HOJA 2 y documentar por qué no está disponible. La ausencia de datos es también información: indica qué capacidades de medición hay que desarrollar. Las métricas sin datos no contribuyen al IGM_Global (se excluyen del cálculo para no sesgar el resultado).

¿Con qué frecuencia debo actualizar las métricas?

Depende del tipo de métrica:

- Métricas de tiempo real (TCKEV, TMCE, TMCD): diario/semanal

- Métricas operativas (MTTR, TVER, TMDE): mensual
- Métricas estructurales (ALE, UMPA, CCUC, RTO gap): trimestral/semestral
- Métricas post-incidente (CUA, TBNO): por incidente + revisión anual

¿Es compatible con el ENS y MAGERIT?

Sí. Las métricas están explícitamente mapeadas a los controles del ENS y a las fases de MAGERIT v3 en el Documento D. El IGM_Global puede usarse como indicador complementario en los informes de seguimiento ENS.

¿Es compatible con ISO 27001?

Sí. El Documento D incluye la correspondencia con los controles de ISO 27001:2022 (Anexo A). El kit puede complementar (no sustituir) el análisis de riesgos ISO 27001, aportando la perspectiva DREAD sobre las amenazas identificadas.

¿Cómo se diferencia este kit del INCIBE-IMC?

El INCIBE-IMC (Marco de Indicadores de Ciberresiliencia) es un marco de referencia nacional. El presente kit es un instrumento de medición compatible con el IMC que añade tres elementos: (1) la trazabilidad GQM desde objetivos nacionales, (2) la evaluación de calidad PRAGMATIC de las métricas, y (3) el contexto DREAD para la priorización de amenazas específicas.

¿Qué pasa con DREAD en entornos OT/ICS?

Las cinco dimensiones DREAD son aplicables a entornos OT/ICS con ajustes en los umbrales (especialmente D y A, donde el impacto físico puede ser catastrófico). Para OT/ICS, se recomienda combinar este kit con IEC 62443-3-2 para el análisis de riesgos y ajustar los pesos sectoriales al preset "Manufactura/OT" de la HOJA 4 del Excel.

FUENTES CIENTÍFICAS Y NORMATIVAS DE REFERENCIA

Metodologías base

Fuente	Tipo	Relevancia para el kit
Basili, V.R., Caldiera, G., Rombach, H.D. (1994). "The Goal Question Metric Approach". Encyclopedia of Software Engineering. Wiley.	Artículo científico seminal	Fundamento metodológico GQM
Brotby, W.K., Hinson, G. (2013). PRAGMATIC Security Metrics: Applying Metametrics to Information Security. CRC Press/Taylor & Francis.	Libro técnico	Fundamento metodológico PRAGMATIC
Calvo, I., Beltrán, M. (2024). "A Goal-Question-Metric framework for cybersecurity risk management". Information & Computer Security, Emerald.	Artículo revisado por pares	GQM dinámico para ciberseguridad
Zahid, A. et al. (2025). "DREAD Security Risk Assessment in Artificial Intelligence (LLMs)". University of Waikato. arXiv preprint.	Preprint académico	DREAD aplicado a IA/LLMs

Marcos de vulnerabilidades y scoring

Fuente	Tipo	Relevancia
FIRST.org. (2025). "EPSS v3: Exploit Prediction Scoring System". first.org/epss	Documentación técnica oficial	R.M2 — TVER
CISA. (2025). "Known Exploited Vulnerabilities Catalog". cisa.gov/kev	Base de datos oficial gubernamental	E.M2 — TCKEV
NIST. (2024). "Common Vulnerability Scoring System v4.0". NVD/nvd.nist.gov	Estándar técnico oficial	E.M1 — SMEC
OWASP. (2025). "OWASP LLM Top 10 v2025". owasp.org	Documentación técnica oficial	E.M3 — DREAD-E LLM

Marco normativo español y europeo

Normativa	Tipo	Relevancia
Directiva (UE) 2022/2555 (NIS2)	Directiva europea	Marco regulatorio principal
Ley de Coordinación y Gobernanza de la Ciberseguridad (LCGC-2025)	Ley española	Transposición NIS2 en España
Reglamento (UE) 2022/2554 (DORA)	Reglamento europeo	Sector financiero; en vigor enero 2025
Reglamento (UE) 2024/2847 (CRA)	Reglamento europeo	Productos con elementos digitales
Real Decreto 311/2022 (ENS)	Real Decreto español	Esquema Nacional de Seguridad
Reglamento (UE) 2016/679 (GDPR) + LOPDGDD	Reglamento europeo + Ley española	Protección de datos personales
ISO/IEC 27001:2022	Norma internacional	SGSI y gestión de riesgos
IEC 62443-2-1	Norma internacional	Seguridad en sistemas de control industrial

Informes de referencia para benchmarking

Informe	Emisor	Periodicidad
Informe de Ciberseguridad en España	INCIBE	Anual
NIS Investments Report	ENISA	Anual
ENISA Threat Landscape (ETL)	ENISA	Anual
Cost of a Data Breach Report	IBM/Ponemon	Anual
Verizon Data Breach Investigations Report (DBIR)	Verizon	Anual
OT/ICS Cybersecurity Year in Review	Dragos	Anual
CrowdStrike Global Threat Report	CrowdStrike	Anual
Microsoft Digital Defense Report	Microsoft	Anual

CONTROL DE VERSIONES

Versión	Fecha	Cambios	Autor
1.0	Abril 2026	Versión inicial del kit completo (7 documentos)	Consortio GQM+PRAGMATIC
1.1	[pendiente]	Actualización con ENISA ETL 2026	[por determinar]
2.0	[pendiente]	Incorporación de vectores cuánticos y IA avanzada	[por determinar]

LICENCIA Y AUTORÍA

Licencia: Creative Commons Attribution 4.0 International (CC BY 4.0)

Puede copiar, redistribuir, modificar y usar este material para cualquier propósito, incluido uso comercial, siempre que cite la fuente original y los cambios realizados.

Cita sugerida para uso académico:

Consortio GQM+PRAGMATIC DREAD (2026). Kit de Medición de Ciberseguridad GQM+PRAGMATIC aplicado al Marco DREAD. Edición 2025-2026. Marco de referencia para evaluación de métricas de ciberseguridad en España. Creative Commons Attribution 4.0 International.

CONTACTO Y CONTRIBUCIONES

Este kit es un documento vivo. Las sugerencias de mejora, las adaptaciones sectoriales y los casos de uso reales son bienvenidos para enriquecer versiones futuras.

Áreas prioritarias para contribuciones:

- Benchmarks sectoriales adicionales (telecomunicaciones, transporte, agua)
- Adaptaciones para PYME (simplificación de métricas para organizaciones sin equipo de seguridad dedicado)
- Integración con herramientas de automatización (SOAR, CSPM, VM platforms)
- Extensión a vectores de amenaza emergentes (computación cuántica, deepfakes técnicos)

README del Kit GQM+PRAGMATIC DREAD · Documento G · Abril 2026

Basado en metodologías de: Basili et al. (1994), Brothy & Hinson (2013)

Alineado con: LCGC-2025, NIS2, DORA, CRA, ENS, GDPR, ISO 27001:2022